

Escape all HTML to prevent XSS attack

#2090

New issue

Merged

jlowin merged 1 commit into `main` from `xss` on Oct 15, 2025

💬 Conversation 0

🔗 Commits 1

📄 Checks 10

📄 Files changed 3

+167 -5

 **jlowin** commented on Oct 15, 2025 Owner

The OAuth callback page embedded user-controlled query parameters directly into HTML without escaping, creating a reflected XSS vulnerability. An attacker could inject malicious JavaScript through parameters like `error` or `error_description`, which would execute in the victim's browser when the callback page rendered.

This adds `html.escape()` to all UI utility functions that render user content, ensuring XSS payloads are properly escaped before rendering. The fix applies escaping at the start of each function for clarity and maintainability.

Reviewers
No reviews

Assignees
No one assigned

Labels
`bug` `client`

Projects
None yet

- Escape all HTML to prevent XSS attack** ✓ `e04b5d5`
- marvin-context-protocol** bot added `bug` `client` `auth` labels on Oct 15, 2025
- jlowin** removed the `auth` label on Oct 15, 2025
- jlowin** merged commit `2a20f54` into `main` View details
on Oct 15, 2025
10 checks passed

Milestone
No milestone

Development
Successfully merging this pull request may close these issues.

None yet

2 participants

jlowin deleted the `xss` branch 3 months ago